UNIVERSIDADE FEDERAL DO OESTE DO PARÁ – CAMPUS ORIXIMINÁ
BACHARELADO EM SISTEMAS DE INFORMAÇÃO
SIMULADO DE SEGURANÇA DA INFORMAÇÃO - ENADE

Prof. Raimundo Júnior

QUESTÃO 01 | Tríade CIA — Conceitos Fundamentais [1 CORRETA]

Durante uma auditoria de segurança em uma instituição financeira, verificou-se que um funcionário não autorizado conseguiu visualizar o saldo bancário de diversos clientes, embora não tenha alterado nenhum dado. Qual pilar fundamental da segurança da informação foi diretamente violado?

A) Disponibilidade.

B) Confidencialidade.

C) Integridade.

D) Não repúdio.

E) Autenticidade.

QUESTÃO 02 | Integridade e Hash Criptográfico [2 CORRETAS]

Um administrador de sistemas precisa garantir que um arquivo de atualização de software baixado pelos clientes não tenha sido alterado durante o transporte na rede. Quais dos seguintes mecanismos e princípios aplicam-se a essa necessidade? (Selecione 2 alternativas corretas)

A) Utilização de uma função de hash (como SHA-256) para validação do checksum.

B) Princípio da Confidencialidade, garantindo o sigilo absoluto do arquivo.

C) Princípio da Integridade, assegurando que o dado não foi modificado de forma não autorizada.

D) Criptografia simétrica com chave privada distribuída publicamente a todos os usuários.

E) Ataque de negação de serviço (DoS) para verificar a consistência do download.

QUESTÃO 03 | Criptografia Simétrica vs. Assimétrica [1 CORRETA]

Na criptografia assimétrica (ou de chave pública), cada entidade possui um par de chaves (uma pública e uma privada). Se a usuária Alice deseja enviar uma mensagem confidencial para o usuário Bob, qual chave Alice deve utilizar para cifrar a mensagem?

A) A chave privada de Alice.

B) A chave pública de Alice.

C) A chave pública de Bob.

D) A chave privada de Bob.

E) Uma chave secreta compartilhada previamente entre Alice e Bob.

QUESTÃO 04 | Assinatura Digital e Não Repúdio [2 CORRETAS]

Assinaturas digitais são amplamente empregadas em transações eletrônicas e documentos oficiais. Quais dos seguintes objetivos de segurança e procedimentos são diretamente atendidos pela assinatura digital? (Selecione 2 alternativas corretas)

A) Garantia de Não Repúdio (irretratabilidade), impedindo que o emissor negue a autoria.

B) Ocultação do conteúdo do documento para que terceiros não consigam lê-lo.

C) Garantia da Autenticidade da origem e da Integridade do conteúdo assinado.

D) Aumento automático da largura de banda no canal de comunicação.

E) Eliminação da necessidade de utilizar certificados digitais na infraestrutura PKI.

QUESTÃO 05 | Ameaças e Engenharia Social **[1 CORRETA]**

Um funcionário de uma empresa recebe um e-mail com logotipo idêntico ao de seu banco corporativo, solicitando a 'atualização urgente de credenciais de acesso' através de um link fraudulento. Essa técnica maliciosa de engenharia social é denominada:

A) Ransomware.

B) Phishing.

C) Keylogger.

D) Man-in-the-Middle.

E) Trojan Horse.

QUESTÃO 06 | Malware — Ransomware e Worms **[2 CORRETAS]**

Diferentes tipos de malwares possuem formas distintas de infecção, propagação e impacto nos sistemas. Avalie as características apresentadas a seguir e assinale as duas alternativas verdadeiras: (Selecione 2 alternativas corretas)

A) O Ransomware criptografa os arquivos da vítima e exige um resgate para o fornecimento da chave de decodificação.

B) Um Worm necessita obrigatoriamente da execução de um arquivo hospedeiro por parte do usuário para se propagar.

C) Um Worm é capaz de se propagar autonomamente pela rede explorando vulnerabilidades sem intervenção humana.

D) O Spyware tem como objetivo primário indisponibilizar servidores Web por meio de requisições massivas.

E) O Rootkit é um hardware físico projetado exclusivamente para interceptar conexões Wi-Fi.

QUESTÃO 07 | Controle de Acesso — Autenticação Multifator (MFA) **[1 CORRETA]**

A Autenticação Multifator (MFA) exige a combinação de diferentes fatores de autenticação para conceder acesso a um sistema. Qual das opções a seguir representa uma combinação válida de 3 fatores de autenticação distintos?

A) Uma senha alfanumérica, um código PIN de 4 dígitos e uma pergunta secreta.

B) Uma senha pessoal, um token gerador de código OTP (hardware) e a leitura da impressão digital.

C) O número do CPF, a data de nascimento e o nome da mãe do usuário.

D) Reconhecimento facial, leitura da íris e impressão digital do mesmo indivíduo.

E) Um certificado digital em cartão inteligente, um token USB e uma chave física.

QUESTÃO 08 | Segurança em Redes — Firewalls **[1 CORRETA]**

Um Firewall de filtragem de pacotes estateless (sem estado) atua na camada de rede e transporte. Qual combinação de informações este tipo de firewall examina nos cabeçalhos para permitir ou bloquear um tráfego?

A) Conteúdo do corpo de e-mails e anexos executáveis.

B) Endereços IP de origem/destino, portas de origem/destino e protocolo (TCP/UDP).

C) Consultas SQL e scripts de entrada em formulários Web.

D) Registro de logs de auditoria do sistema operacional local.

E) Chaves públicas contidas em certificados digitais X.509.

QUESTÃO 09 | Ataques de Negação de Serviço (DoS / DDoS) **[2 CORRETAS]**

Um ataque de Negação de Serviço Distribuído (DDoS) visa indisponibilizar um serviço na internet. Quais são as principais características desse tipo de ataque? (Selecione 2 alternativas corretas)

A) O ataque compromete a Confidencialidade dos dados ao roubar senhas de administradores.

B) O ataque afeta diretamente a Disponibilidade do sistema, esgotando recursos como memória, processamento ou largura de banda.

C) Utiliza frequentemente uma rede de computadores zumbis (Botnet) distribuídos globalmente para gerar alto volume de tráfego.

D) Tem como principal objetivo alterar o código-fonte das aplicações armazenadas no servidor.

E) Funciona apenas contra redes locais que não utilizam cabos de fibra óptica.

QUESTÃO 10 | Vulnerabilidades Web — SQL Injection **[1 CORRETA]**

Uma aplicação Web vulnerável a SQL Injection permite que um atacante insira comandos SQL maliciosos em campos de entrada de formulários. Qual das seguintes práticas de desenvolvimento é a medida defensiva mais eficaz para conter essa ameaça?

A) Ocultar os formulários utilizando folhas de estilo CSS.

B) Utilizar consultas preparadas (Prepared Statements / Parameterized Queries).

C) Armazenar as senhas no banco de dados utilizando criptografia reversível.

D) Desabilitar o protocolo HTTPS no servidor de aplicação.

E) Aumentar a quantidade de memória RAM alocada para o banco de dados.

QUESTÃO 11 | Vulnerabilidades Web — XSS (Cross-Site Scripting) **[2 CORRETAS]**

O Cross-Site Scripting (XSS) é uma vulnerabilidade clássica em aplicações Web. Quais afirmações abaixo descrevem corretamente o funcionamento e prevenção do XSS? (Selecione 2 alternativas corretas)

A) Ocorre quando a aplicação insere dados não confiáveis na página Web sem a devida validação ou codificação (escaping).

B) Permite que scripts maliciosos (como JavaScript) sejam executados no navegador do cliente/vítima.

C) Consiste em formatar o disco rígido do servidor de banco de dados diretamente via BIOS.

D) A principal forma de conter o XSS é desativar a placa de rede do cliente.

E) Afeta exclusivamente servidores operando com o sistema operacional Linux.

QUESTÃO 12 | Protocolos Seguros — HTTPS e TLS **[1 CORRETA]**

Ao navegar em um site bancário que utiliza o protocolo HTTPS (HTTP sobre TLS/SSL), o navegador do usuário estabelece uma conexão segura. Qual é o papel dos certificados digitais X.509 e da Infraestrutura de Chaves Públicas (PKI) nesse processo?

A) Garantir a limpeza automática de vírus no computador do usuário.

B) Validar a identidade do servidor Web e fornecer a chave pública para o acordo de chaves da sessão.

C) Impedir que o usuário digite senhas incorretas na tela de login.

D) Converter o banco de dados relacional do servidor em um banco de dados NoSQL.

E) Acelerar a velocidade física de transmissão de dados do provedor de internet.

QUESTÃO 13 | Funções de Hash e Suas Propriedades **[2 CORRETAS]**

As funções de hash criptográficas são algoritmos unidirecionais cruciais para a segurança da informação. Quais são duas propriedades fundamentais exigidas de uma função de hash segura? (Selecione 2 alternativas corretas)

A) Resistência à pré-imagem (dada a saída hash h, deve ser computacionalmente inviável encontrar a entrada x tal que hash(x) = h).

B) Reversibilidade direta, permitindo recuperar facilmente a mensagem original a partir do resumo hash.

C) Resistência à colisão (deve ser computacionalmente inviável encontrar duas entradas distintas x e y tais que hash(x) = hash(y)).

D) Variação do tamanho da saída de acordo com o tamanho do texto digitado pelo usuário.

E) Dependência obrigatória de uma conexão ativa com a internet para gerar o hash.

QUESTÃO 14 | Princípios de Segurança — Menor Privilégio e Defesa em Profundidade **[1 CORRETA]**

O Princípio do Menor Privilégio (*Principle of Least Privilege*) é uma diretriz fundamental na gestão de acessos. Esse princípio estabelece que:

A) Todos os funcionários da empresa devem ter acesso total de administrador para facilitar a agilidade das rotinas de trabalho.

B) Cada usuário ou processo deve possuir apenas os privilégios mínimos estritamente necessários para a execução de suas tarefas autorizadas.

C) O sistema de segurança deve conter apenas uma única camada de proteção para evitar custos excessivos de infraestrutura.

D) As senhas de usuários comuns devem ter no máximo 4 caracteres numéricos sem expiração.

E) Apenas o departamento de TI tem permissão para acessar a rede de internet da empresa.

QUESTÃO 15 | Ataques Man-in-the-Middle (MitM) e ARP Spoofing **[2 CORRETAS]**

No ataque conhecido como *Man-in-the-Middle* (MitM), um atacante intercepta a comunicação entre duas partes sem que elas saibam. Quais dos itens a seguir representam formas de execução ou prevenção desse ataque? (Selecione 2 alternativas corretas)

A) O envenenamento de cache ARP (ARP Spoofing) é uma técnica comum para executar MitM em uma rede local ethernet.

B) A utilização de criptografia forte fim-a-fim com verificação rigorosa de certificados digitais previne a interceptação de dados sensíveis.

C) O ataque MitM só é possível se o atacante estiver fisicamente dentro do data center da empresa.

D) O protocolo HTTP sem criptografia é imune a ataques Man-in-the-Middle.

E) A troca de placas de vídeo nos computadores clientes impede a interceptação do tráfego de rede.

QUESTÃO 16 | Políticas de Segurança e Gestão de Riscos (ISO/IEC 27001) **[2 CORRETAS]**

No âmbito da gestão corporativa de Segurança da Informação (normas da família ISO/IEC 27000), quais das seguintes afirmações sobre Gestão de Riscos e Políticas de Segurança são corretas? (Selecione 2 alternativas corretas)

A) O risco de segurança da informação é calculado como uma combinação da probabilidade de ocorrência de um evento e seu impacto nos ativos.

B) Uma Política de Segurança da Informação (PSI) é um documento puramente técnico que não exige apoio nem aprovação da alta direção.

C) As medidas de salvaguarda/controles podem ser de natureza técnica, administrativa (organizacional) ou física.

D) A ISO 27001 garante que uma empresa que a cumpra estará 100% imune a qualquer ataque cibernético existente.

E) A gestão de riscos orienta a empresa a gastar recursos infinitos em segurança, independentemente do valor do ativo.

QUESTÃO 17 | Engenharia Social — Spear Phishing vs. Social Engineering **[1 CORRETA]**

Uma empresa de tecnologia sofreu um incidente em que o diretor financeiro recebeu um e-mail altamente personalizado, contendo dados reais sobre contratos recentes da empresa, solicitando a transferência urgente de fundos para uma conta bancária externa. Esse tipo de ataque altamente direcionado é denominado:

A) Spam de massa.

B) Spear Phishing (ou CEO Fraud / Whaling).

C) Cross-Site Request Forgery (CSRF).

D) Scan de portas TCP.

E) Buffer Overflow.

QUESTÃO 18 | Segurança em Nuvem e Responsabilidade Compartilhada **[2 CORRETAS]**

No modelo de computação em nuvem, a segurança é regida pelo Modelo de Responsabilidade Compartilhada (*Shared Responsibility Model*). Avalie as responsabilidades no modelo IaaS (Infraestrutura como Serviço) e assinale as duas alternativas corretas: (Selecione 2 alternativas corretas)

A) O provedor de nuvem é responsável pela segurança física dos Data Centers e pela infraestrutura de hardware subjacente.

B) O cliente é totalmente isento de aplicar atualizações de segurança e patches no sistema operacional das suas máquinas virtuais.

C) O cliente é responsável por configurar o firewall virtual, gerenciar o sistema operacional da VM e proteger seus dados.

D) O provedor de nuvem assume a responsabilidade total pelo gerenciamento de senhas e credenciais dos usuários do cliente.

E) No modelo IaaS, o cliente não tem controle sobre o sistema operacional instalado na nuvem.